

مستند API سامانه SaaS Chat AI

بخش ۹ راهنمای مستندات پروژه

نسخه سند: ۰.۱

تاریخ تدوین: ۱۵ جولای ۲۰۲۶

تهیه کننده: مبین یوسفی

مسیر خروجی: doc/LaTeX/09-API/09-API.tex

منابع بررسی شده: ArchitectureForMobin.md، Rahnama.md،

ReportForSale.md و کدهای backend/api

مستند فنی رابط‌های برنامه نویسی، قراردادهای درخواست/پاسخ، کنترل دسترسی و
جریان‌های اصلی مصرف API

فهرست مطالب

۳	۱ هدف و دامنه سند
۳	۲ قراردادهای عمومی API
۳	۱.۲ آدرس پایه
۳	۲.۲ قالب داده و هدرها
۳	۳.۲ قالب پاسخ موفق و خطا
۴	۴.۲ کدهای وضعیت HTTP
۵	۵.۲ احراز هویت و نقش ها
۵	۳ کاتالوگ ها Endpoint
۵	۱.۳ احراز هویت
۵	۲.۳ ویجت عمومی
۶	۳.۳ پنل اپراتور
۸	۴.۳ پنل مشتری
۱۰	۵.۳ پنل سوپرادمین
۱۲	۴ جریان های عملیاتی و نمونه قرارداد
۱۲	۱.۴ ورود و استفاده از توکن
۱۳	۲.۴ جریان راه اندازی ویجت
۱۴	۳.۴ جریان اپراتور و پیشنهاد AI
۱۵	۴.۴ جریان مدیریت AI و دانش در پنل مشتری
۱۶	۵.۴ جریان مدیریت مشتری و پلن توسط سوپرادمین
۱۶	۵ قواعد امنیتی و عملیاتی
۱۷	۱.۵ JWT و ابطال نشست
۱۷	۲.۵ کنترل نقش و مالکیت داده
۱۷	۳.۵ امنیت ویجت عمومی
۱۷	۴.۵ محدودیت نرخ
۱۷	۵.۵ بارگذاری فایل
۱۷	۶.۵ حذف اطلاعات حساس از خطا
۱۸	۶ نسخه بندی و سازگاری
۱۸	۷ نکات تکمیلی و ریسک های شناخته شده

۱ هدف و دامنه سند

این سند قراردادهای API سامانه AI Chat SaaS را برای مصرف‌کنندگان داخلی و خارجی توضیح می‌دهد. دامنه سند شامل های API احراز هویت، ویجت عمومی، پنل اپراتور، پنل مشتری و پنل سوپرادمین است. مبنای تدوین، کدهای فعلی پوشه backend/api و قواعد معماری پروژه است؛ بنابراین نام، endpointها، روش احراز هویت، نقش‌های مجاز، وضعیت‌های خطا و جریان‌های عملیاتی با پیاده‌سازی موجود هماهنگ شده‌اند.

سامانه از معماری API Plain PHP روی PDO/MySQL استفاده می‌کند. هر فایل PHP در پوشه backend/api عملاً یک endpoint مستقل است و مسیریاب مرکزی یا نسخه‌بندی مسیر مانند /api/v1 در وضعیت فعلی وجود ندارد. پاسخ‌ها با قالب JSON، هدرهای امنیتی پایه و وضعیت HTTP مناسب تولید می‌شوند.

۲ قراردادهای عمومی API

۱.۲ آدرس پایه

در محیط واقعی، آدرس پایه باید با دامنه نصب‌شده پروژه جایگزین شود. در این سند از نمونه زیر استفاده می‌شود:

```
https://api.example.com/backend/api
```

نمونه مسیر کامل:

```
POST https://api.example.com/backend/api/auth/login.php
```

۲.۲ قالب داده و هدرها

- پاسخ‌ها با Content-Type: application/json; charset=utf-8 برگردانده می‌شوند.
- درخواست‌های معمولی با Content-Type: application/json ارسال می‌شوند.
- های endpoint بارگذاری فایل مانند attachment-send.php و announcement-image-upload.php از multipart/form-data استفاده می‌کنند.
- های API پنل با هدر Authorization: Bearer <token> محافظت می‌شوند.
- های API عمومی ویجت به جای JWT از site_key، کنترل مبدا Origin و محدودیت نرخ استفاده می‌کنند.

۳.۲ قالب پاسخ موفق و خطا

قالب پاسخ‌ها بسته به endpoint شامل فیلدهای داده‌ای متفاوت است، اما الگوی غالب به شکل زیر است:

```
{
  "success": true,
```

```
,completed" "Operation "message":
{} "data":
}
```

نمونه خطا:

```
{
  "success":
    ,false "message":
      "Unauthorized"
}
```

در محیط production، پاسخ‌های ۵xx توسط لایه مشترک پاسخ‌دهی پاک‌سازی می‌شوند و کلیدهای حساس مانند debug، trace، file، line، sql و pdo_error از خروجی حذف می‌شوند.

۴.۲ کدهای وضعیت HTTP

کد	معنا در سامانه
200	عملیات خواندن یا به‌روزرسانی با موفقیت انجام شده است.
201	موجودیت جدید مانند مشتری، پلن، پاسخ آماده یا منبع دانش ایجاد شده است.
204	پاسخ preflight برای درخواست OPTIONS در های API ویجت.
400	پارامترهای الزامی ناقص، مقدار نامعتبر، شناسه نامعتبر یا درخواست ناسازگار با وضعیت فعلی.
401	توکن ارسال نشده، نامعتبر است یا کاربر احراز هویت نشده است.
403	نقش کاربر، وضعیت tenant، وضعیت سایت یا دسترسی به قابلیت پلن اجازه انجام عملیات را نمی‌دهد.
404	موجودیت هدف مانند گفتگو، سایت، کاربر، مشتری، پلن یا اعلان پیدا نشده است.
405	متد HTTP endpoint رعایت نشده است.
422	داده معتبر از نظر ساختار ارسال شده، اما از نظر قواعد دامنه قابل پذیرش نیست.
429	محدودیت نرخ برای شناسه درخواست‌کننده فعال شده است و باید بعد از Retry-After تلاش شود.
500	خطای داخلی سرور یا خطای وابستگی مانند پایگاه داده/ماژول هوش مصنوعی.

۵.۲ احراز هویت و نقش‌ها

توکن JWT در login صادر می‌شود و در های API پل استفاده می‌گردد. اعتبار توکن فقط به امضای JWT محدود نیست؛ هنگام هر درخواست، کاربر از پایگاه داده خوانده می‌شود، فعال بودن او بررسی می‌شود، مقدار token_version با payload توکن تطبیق داده می‌شود و برای کاربران غیرسوپردمین، فعال بودن tenant نیز کنترل می‌شود.

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9... Bearer Authorization:
```

نقش‌های اصلی:

- **super_admin**: مدیریت کل سامانه، ها، مشتریان، پلن‌ها، سایت‌ها، اعلان‌ها و مانیتورینگ.
- **customer_admin**: مدیریت سایت‌های tenant، تیم، تنظیمات ویجت، دانش، AI و گزارش‌ها.
- **agent**: پاسخ‌گویی به گفتگوها، مشاهده اعلان‌ها، حضور آنلاین و استفاده از پیشنهادهای AI در محدوده سایت‌های مجاز.

۳ کاتالوگ Endpointها

۱.۳ احراز هویت

Endpoint	متد	دسترسی	ورودی اصلی	خروجی/خطا
auth/login.php	POST	عمومی	password, email	صدور توکن، اطلاعات کاربر و tenant؛ خطا برای اعتبارنامه نامعتبر یا کاربر/tenant غیرفعال.
auth/me.php	GET	JWT	بدون بدنه	اطلاعات کاربر فعلی و زمینه دسترسی.
auth/change-password.php	POST	JWT	current_password, new_password	تغییر رمز کاربر؛ خطا برای رمز فعلی نادرست یا رمز جدید نامعتبر.
auth/logout-all.php	POST	JWT	بدون بدنه	افزایش token_version و ابطال همه توکن‌های قبلی کاربر.

۲.۳ ویجت عمومی

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
تنظیمات ظاهری و رفتاری ویجت؛ خطا برای سایت نامعتبر یا غیرفعال.	site_key	عمومی با site_key و Origin	GET	widget/config.php
ایجاد/بهروزرسانی visitor و بازگرداندن visitor_id	browser_id, site_key, اطلاعات اختیاری بازدیدکننده	عمومی با کنترل نرخ	POST	widget/visitor-start.php
ایجاد گفتگو یا بازگرداندن گفتگوی باز؛ خطا برای visitor نامعتبر یا محدودیت پلن.	visitor_id, site_key, source_url, source_title	عمومی با کنترل نرخ	POST	widget/conversation-start.php
ثبت پیام بازدیدکننده و بهروزرسانی گفتگو؛ خطا برای گفتگوی بسته یا متن بیش از حد.	visitor_id, site_key, conversation_id, content	عمومی با کنترل نرخ	POST	widget/message-send.php
بارگذاری پیوست و ثبت پیام فایل.	visitor_id, site_key, file, conversation_id, پیام اختیاری	عمومی، multipart/form-data	POST	widget/attachment-send.php
فهرست پیام‌های گفتگو برای سمت polling ویجت.	visitor_id, site_key, conversation_id	عمومی با site_key	GET	widget/messages-list.php
وضعیت تایپ اپراتور/سیستم.	visitor_id, site_key, conversation_id	عمومی با site_key	GET	widget/typing-status.php
تولید پاسخ خودکار AI در صورت فعال بودن؛ خطا برای پاسخ تکراری، گفتگوی بسته، اپراتور آنلاین یا غیرفعال.	visitor_id, site_key, conversation_id, message_id	عمومی با کنترل نرخ و تنظیمات AI	POST	widget/ai-reply.php

۳.۳ پنل اپراتور

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
فهرست گفتگوهای قابل مشاهده برای کاربر.	فیلترهای اختیاری مانند سایت، وضعیت، جست‌وجو و صفحه‌بندی	customer_admin agent	GET	agent/conversations-list.php
جزئیات گفتگو، پیام‌ها، visitor و وضعیت انتساب.	conversation_id	نقش‌های اپراتوری + دسترسی سایت	GET	agent/conversation-show.php
ثبت پاسخ اپراتور؛ خطا برای گفتگوی بسته یا دسترسی نامعتبر.	conversation_id, content	نقش‌های اپراتوری + دسترسی سایت	POST	agent/message-send.php
بارگذاری فایل اپراتور و ثبت پیام پیوست.	conversation_id, file	نقش‌های اپراتوری، multipart/form-data	POST	agent/attachment-send.php
انتساب گفتگو به اپراتور مجاز یا آزادسازی انتساب.	conversation_id, agent_id	نقش‌های اپراتوری + دسترسی سایت	POST	agent/conversation-assign.php
تغییر وضعیت گفتگو مانند باز/در حال پیگیری/بسته.	conversation_id, status	نقش‌های اپراتوری + دسترسی سایت	POST	agent/conversation-status-update.php
بستن گفتگو.	conversation_id	نقش‌های اپراتوری + دسترسی سایت	POST	agent/conversation-close.php
به‌روزرسانی حضور اپراتور برای تصمیم‌گیری پاسخ خودکار.	status, site_id	نقش‌های اپراتوری	POST	agent/presence-update.php
دریافت یا به‌روزرسانی وضعیت حضور.	site_id, وضعیت در حالت POST	نقش‌های اپراتوری	GET/POST	agent/presence-status.php
ثبت وضعیت تایپ برای ویجت.	conversation_id, is_typing	نقش‌های اپراتوری + دسترسی سایت	POST	agent/typing-update.php
دریافت پاسخ‌های آماده سایت.	site_id	نقش‌های اپراتوری + دسترسی سایت	GET	agent/quick-replies-list.php
فهرست اپراتورهای قابل انتساب.	site_id یا conversation_id	نقش‌های اپراتوری + دسترسی سایت	GET	agent/assignable-agents-list.php
تولید پیشنهاد پاسخ AI برای اپراتور.	conversation_id, message_id	نقش‌های اپراتوری + قابلیت پلن	POST	agent/suggestion-generate.php

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
فهرست پیشنهادهای تولیدشده برای گفتگو.	conversation_id	نقش‌های اپراتوری + دسترسی سایت	GET	agent/ai-suggestions-list.php
پذیرش پیشنهاد و آماده‌سازی متن برای ارسال/ثبت.	suggestion_id	نقش‌های اپراتوری + دسترسی سایت	POST	agent/ai-suggestion-accept.php
علامت‌گذاری پیشنهاد به‌عنوان استفاده‌شده.	suggestion_id	نقش‌های اپراتوری + دسترسی سایت	POST	agent/ai-suggestion-mark-used.php

۴.۳ پنل مشتری

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
سایت‌های قابل مشاهده tenant.	بدون بدنه	customer_admin, agent	GET	customer/sites-list.php
به‌روزرسانی ظاهر و رفتار ویجت.	site_id و تنظیمات ویجت	customer_admin	POST	customer/widget-settings-update.php
فهرست اعضای تیم.	فیلترهای اختیاری	customer_admin	GET	customer/team-list.php
ایجاد کاربر تیمی.	نام، ایمیل، نقش و سایت‌های مجاز	customer_admin	POST	customer/team-create.php
مصرف پلن، محدودیت‌ها و قابلیت‌ها.	بدون بدنه	customer_admin	GET	customer/plan-usage.php
خلاصه گفتگوها، عملکرد و شاخص‌های عملیاتی.	بازه زمانی/سایت اختیاری	customer_admin	GET	customer/reports-summary.php
فهرست پاسخ‌های آماده.	site_id اختیاری	customer_admin	GET	customer/quick-replies-list.php
ایجاد پاسخ آماده.	title, site_id, content	customer_admin	POST	customer/quick-replies-create.php
حذف پاسخ آماده.	id	customer_admin	POST	customer/quick-replies-delete.php

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
فهرست اعلان‌های هدف‌گذاری‌شده.	وضعیت خوانده‌شدن اختیاری	customer_admin agent	GET	customer/announcements-list.php
ثبت خوانده‌شدن اعلان.	announcement_id	customer_admin agent	POST	customer/announcement-read.php
بستن/نادیده‌گرفتن اعلان برای کاربر.	announcement_id	customer_admin agent	POST	customer/announcement-dismiss.php
فهرست دانش دستی سایت.	site_id جست‌وجو/صفحه‌بندی اختیاری	customer_admin	GET	customer/knowledge-list.php
ایجاد آیتم دانش برای پاسخ‌دهی AI.	question, site_id, answer	customer_admin	POST	customer/knowledge-create.php
حذف آیتم دانش.	id	customer_admin	POST	customer/knowledge-delete.php
دریافت/ثبت فعال‌سازی AI، حالت خودکار و پارامترهای پاسخ.	site_id و تنظیمات AI در POST	customer_admin	GET/POST	customer/ai-settings.php
آزمون جست‌وجوی دانش و کیفیت بازیابی.	query, site_id	customer_admin	POST	customer/ai-search-test.php
نمای کلی منابع دانش، سوالات بی‌پاسخ و وضعیت AI.	site_id اختیاری	customer_admin	GET	customer/ai-overview.php
فهرست منابع خزنده.	site_id	customer_admin	GET	customer/ai-crawl-sources-list.php
ایجاد منبع خزنده.	url, site_id, تنظیمات crawl	customer_admin	POST	customer/ai-crawl-source-create.php
حذف منبع خزنده.	id	customer_admin	POST	customer/ai-crawl-source-delete.php
شروع پردازش crawl و استخراج دانش.	site_id یا source_id	customer_admin	POST	customer/ai-crawl-start.php

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
فهرست منابع دانش ساخت‌یافته AI.	site_id	customer_admin	GET	customer-admin/ai-knowledge-sources-list.php
ایجاد منبع دانش AI.	site_id	customer_admin	POST	customer-admin/ai-knowledge-source-create.php
ویرایش منبع دانش AI.	id و فیلدهای قابل ویرایش	customer_admin	POST	customer-admin/ai-knowledge-source-update.php
سوالات پیشنهادی تولیدشده از منابع.	site_id	customer_admin	GET	customer-admin/ai-generated-questions-list.php
تایید، رد یا ویرایش سوال تولیدشده.	id، وضعیت/متن اصلاحی	customer_admin	POST	customer-admin/ai-generated-question-update.php
فهرست سوالات بی‌پاسخ ثبت‌شده از گفتگوها.	site_id، فیلتر وضعیت	customer_admin	GET	customer-admin/ai-unanswered-list.php
تغییر وضعیت سوال بی‌پاسخ.	status, id	customer_admin	POST	customer-admin/ai-unanswered-update-status.php
تبدیل سوال بی‌پاسخ به دانش قابل استفاده.	answer, id	customer_admin	POST	customer-admin/ai-unanswered-add-to-knowledge.php

۵.۳ پنل سوپرادمین

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
آمار کل سامانه.	بدون بدنه	super_admin	GET	super-admin/dashboard-stats.php
فهرست tenantها.	فیلتر/صفحه‌بندی اختیاری	super_admin	GET	super-admin/tenants-list.php
گزینه‌های برای tenant فرم‌ها.	بدون بدنه	super_admin	GET	super-admin/tenants-options.php

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
ایجاد مشتری کامل با کاربر مدیر و سایت اولیه.	tenant_id، مدیر، سایت و پلن	super_admin	POST	super-admin/customer-create.php
جزئیات مشتری، پلن، کاربران و سایت‌ها.	tenant_id یا id	super_admin	GET	super-admin/customer-show.php
فعال/غیرفعال سازی مشتری.	status, tenant_id	super_admin	POST	super-admin/customer-status-update.php
تغییر پلن مشتری.	plan_id, tenant_id	super_admin	POST	super-admin/customer-plan-update.php
فهرست پلن‌ها و قابلیت‌ها.	فیلتر اختیاری	super_admin	GET	super-admin/plans-list.php
ایجاد پلن.	نام، قیمت، محدودیت‌ها و قابلیت‌ها	super_admin	POST	super-admin/plan-create.php
ویرایش پلن.	id و فیلدهای قابل ویرایش	super_admin	POST	super-admin/plan-update.php
فعال/غیرفعال کردن پلن.	id	super_admin	POST	super-admin/plan-toggle-status.php
فهرست سایت‌ها.	tenant یا وضعیت اختیاری	super_admin	GET	super-admin/sites-list.php
ویرایش تنظیمات سایت.	site_id و تنظیمات	super_admin	POST	super-admin/site-settings-update.php
تغییر وضعیت سایت.	status, site_id	super_admin	POST	super-admin/site-status-update.php
فعال/غیرفعال کردن کاربر.	status, user_id	super_admin	POST	super-admin/user-status-update.php
بازنشانی رمز کاربر.	user_id، رمز جدید یا تولید خودکار	super_admin	POST	super-admin/user-password-reset.php
فهرست اعلان‌ها.	فیلتر اختیاری	super_admin	GET	super-admin/announcements-list.php
ایجاد اعلان.	عنوان، متن، نوع، اولویت و هدف‌گیری	super_admin	POST	super-admin/announcement-create.php
ویرایش اعلان.	id و فیلدهای قابل ویرایش	super_admin	POST	super-admin/announcement-update.php
حذف اعلان.	id	super_admin	POST	super-admin/announcement-delete.php
بارگذاری تصویر اعلان.	فایل تصویر	super_admin	POST	super-admin/announcement-image-upload.php

خروجی/خطا	ورودی اصلی	دسترسی	متد	Endpoint
آمار استفاده، خطا و کارایی AI.	بازه/tenant اختیاری	super_admin	GET	super-admin/ai-monitoring-stats.php
لاگ‌های ممیزی عملیات مدیریتی.	فیلتر کاربر، عمل، بازه و صفحه‌بندی	super_admin	GET	super-admin/audit-logs-list.php

۴ جریان‌های عملیاتی و نمونه قرارداد

۱.۴ ورود و استفاده از توکن

درخواست ورود

```
POST /backend/api/auth/login.php
Content-Type: application/json

{
  "email": "admin@example.com",
  "password": "SecretPassword123"
}
```

پاسخ موفق

```
{
  "success": true,
  "message": "Login successful",
  "token": "JWT_TOKEN",
  "user": {
    "id": 12,
    "name": "Admin User",
    "email": "admin@example.com",
    "role": "customer_admin",
    "tenant_id": 4
  }
}
```

دریافت کاربر فعلی

```
GET /backend/api/auth/me.php
Authorization: Bearer JWT_TOKEN
```

ابطال همه نشست‌ها

```
POST /backend/api/auth/logout-all.php
Authorization: Bearer JWT_TOKEN
```

۲.۴ جریان راه‌اندازی ویجت

ویجت سمت سایت مشتری ابتدا تنظیمات را با `site_key` دریافت می‌کند، سپس `visitor` و `conversa-` tion ایجاد می‌کند و پیام‌ها را با `polling` یا درخواست‌های دوره‌ای دریافت می‌کند. همه درخواست‌های ویجت تحت کنترل `Origin` و `limit rate` هستند.

دریافت تنظیمات

```
GET /backend/api/widget/config.php?site_key=site_public_key
Origin: https://customer-site.example
```

ثبت بازدیدکننده

```
POST /backend/api/widget/visitor-start.php
Content-Type: application/json
Origin: https://customer-site.example

{
  "site_key": "site_public_key",
  "browser_id": "browser-uuid",
  "name": "Visitor Name",
  "email": "visitor@example.com",
  "phone": "+989120000000"
}
```

شروع گفتگو

```
POST /backend/api/widget/conversation-start.php
Content-Type: application/json

{
  "site_key": "site_public_key",
  "visitor_id": 345,
  "source_url": "https://customer-site.example/pricing",
  "source_title": "Pricing"
}
```

ارسال پیام بازدیدکننده

```
POST /backend/api/widget/message-send.php
Content-Type: application/json

{
  "site_key": "site_public_key",
  "visitor_id": 345,
  "conversation_id": 890,
  "content": "Hello, I need help choosing a plan."
}
```

درخواست پاسخ خودکار AI

```
POST /backend/api/widget/ai-reply.php
Content-Type: application/json

{
  "site_key": "site_public_key",
  "visitor_id": 345,
  "conversation_id": 890,
  "message_id": 1204
}
```

خواندن پیام‌ها

```
GET /backend/api/widget/messages-list.php?site_key=site_public_key&visitor_id=345&conversation_id=890
```

۳.۴ جریان اپراتور و پیشنهاد AI

اپراتور پس از login گفتگوها را دریافت می‌کند، جزئیات یک گفتگو را می‌بیند و در صورت فعال بودن قابلیت پلن، پیشنهاد پاسخ AI تولید می‌کند. پیشنهاد AI در این سامانه بر اساس موتور محلی/استخراجی و منابع دانش داخلی سایت عمل می‌کند و وابسته به سرویس خارجی LLM در جریان فعال نیست.

```
GET /backend/api/agent/conversations-list.php?site_id=10&status=open
Authorization: Bearer JWT_TOKEN
```

```
GET /backend/api/agent/conversation-show.php?conversation_id=890
Authorization: Bearer JWT_TOKEN
```

```
POST /backend/api/agent/ai-suggestion-generate.php
Authorization: Bearer JWT_TOKEN
Content-Type: application/json

{
  "conversation_id": 890,
  "message_id": 1204
}
```

```
POST /backend/api/agent/message-send.php
Authorization: Bearer JWT_TOKEN
Content-Type: application/json

{
  "conversation_id": 890,
  "content": "Hello, please share your agent count and monthly conversation volume."
}
```

۴.۴ جریان مدیریت AI و دانش در پنل مشتری

مدیر مشتری تنظیمات AI را برای هر سایت مدیریت می‌کند، منابع دانش دستی یا crawl شده را اضافه می‌کند و سوالات بی‌پاسخ را به دانش قابل بازیابی تبدیل می‌کند.

```
GET /backend/api/customer/ai-settings.php?site_id=10
Authorization: Bearer JWT_TOKEN
```

```
POST /backend/api/customer/ai-settings.php
Authorization: Bearer JWT_TOKEN
Content-Type: application/json

{
  "site_id": 10,
  "ai_enabled": true,
  "auto_reply_enabled": true,
  "assistant_name": "Support Assistant",
  "confidence_threshold": 0.65
}
```

```
POST /backend/api/customer/knowledge-create.php
Authorization: Bearer JWT_TOKEN
Content-Type: application/json

{
  "site_id": 10,
  "question": "How can I upgrade my plan?",
  "answer": "Open the billing section in the panel and submit an upgrade request."
}
```

```
POST /backend/api/customer/ai-crawl-source-create.php
Authorization: Bearer JWT_TOKEN
Content-Type: application/json

{
  "site_id": 10,
  "url": "https://customer-site.example/help",
}
```



```
"title": "Help Center"
}
```

```
POST /backend/api/customer/ai-unanswered-add-to-knowledge.php
Authorization: Bearer JWT_TOKEN
Content-Type: application/json

{
  "id": 77,
  "answer": "Approved answer to be added to the knowledge base."
}
```

۵.۴ جریان مدیریت مشتری و پلن توسط سوپرادمین

سوپرادمین، tenant، مدیر مشتری، سایت اولیه و پلن را از های API مدیریتی کنترل می‌کند. این end-pointها فقط با نقش super_admin قابل دسترسی هستند.

```
POST /backend/api/super-admin/customer-create.php
Authorization: Bearer SUPER_ADMIN_JWT
Content-Type: application/json

{
  "tenant_name": "Acme",
  "admin_name": "Acme Admin",
  "admin_email": "admin@acme.example",
  "site_name": "Acme Website",
  "site_domain": "acme.example",
  "plan_id": 2
}
```

```
GET /backend/api/super-admin/plans-list.php
Authorization: Bearer SUPER_ADMIN_JWT
```

```
POST /backend/api/super-admin/customer-plan-update.php
Authorization: Bearer SUPER_ADMIN_JWT
Content-Type: application/json

{
  "tenant_id": 4,
  "plan_id": 3
}
```

۵ قواعد امنیتی و عملیاتی

۱.۵ JWT و ابطال نشست

هر درخواست محافظت شده با `require_auth` اعتبارسنجی می‌شود. علاوه بر بررسی امضای JWT، وضعیت کاربر، نقش، ایمیل، `tenant` و `token_version` کنترل می‌شود. `logout-all.php` endpoint با افزایش `token_version` همه توکن‌های قبلی کاربر را نامعتبر می‌کند.

۲.۵ کنترل نقش و مالکیت داده

های API سوپرادمین فقط برای `super_admin` هستند. های API مشتری عمدتاً فقط برای `customer_admin` باز هستند و های API اپراتوری برای `customer_admin` و `agent`. در عملیات وابسته به سایت، دسترسی کاربر به همان سایت نیز بررسی می‌شود تا کاربر `tenant` یا سایت دیگری را مشاهده یا تغییر ندهد.

۳.۵ امنیت ویجت عمومی

ویجت چون روی دامنه مشتری اجرا می‌شود، JWT دریافت نمی‌کند. امنیت آن با ترکیب چند کنترل برقرار می‌شود:

- الزام `site_key` برای شناسایی سایت.
- کنترل Origin بر اساس دامنه سایت، تنظیمات محیطی و مبداهای توسعه محلی.
- پاسخ OPTIONS با وضعیت 204 برای `preflight`.
- محدودیت نرخ برای عملیات `visitor`، گفتگو، پیام و پاسخ AI.
- رد درخواست برای سایت یا `tenant` غیرفعال و گفتگوی بسته.

۴.۵ محدودیت نرخ

لایه `rate-limit.php` تلاش‌های هر عملیات را با کلید `action` و `identifier` در جدول `api_rate_limits` ذخیره می‌کند. در صورت عبور از سقف، پاسخ 429 همراه با هدر `Retry-After` و فیلد `retry_after_seconds` برگردانده می‌شود.

۵.۵ بارگذاری فایل

های endpoint پیوست و تصویر اعلان باید با `multipart/form-data` فراخوانی شوند. مصرف‌کننده باید نوع فایل، اندازه و خطاهای اعتبارسنجی را در سطح UI مدیریت کند. در سمت سرور، فایل فقط در بستر endpoint مجاز و پس از احراز دسترسی گفتگو/اعلان پردازش می‌شود.

۶.۵ حذف اطلاعات حساس از خطا

تابع مشترک `json_response` در `production` کلیدهای حساس خطاهای ۵xx را حذف می‌کند. بنابراین کلاینت نباید به جزئیات داخلی خطا وابسته شود و باید فقط `success`، `message` و کد HTTP را مبنای تصمیم قرار دهد.

۶ نسخه‌بندی و سازگاری

در نسخه فعلی پروژه، نسخه API در مسیر URL وجود ندارد و endpointها مستقیم زیر backend/api قرار دارند. برای توسعه آتی، پیشنهاد می‌شود نسخه‌بندی صریح مانند /api/v1، قرارداد OpenAPI و migration تدریجی endpointهای فایل‌محور به کنترلرهای ماژولار اضافه شود. تا قبل از آن، تغییر نام فایل‌ها یا تغییر فیلدهای پاسخ باید به‌عنوان تغییر ناسازگار تلقی شود.

۷ نکات تکمیلی و ریسک‌های شناخته‌شده

- فایل agent/ai-suggestion-generate.backup.php یک فایل پشتیبان است و نباید به‌عنوان API فعال در کلاینت‌ها استفاده شود.
- مستند حاضر بر اساس کد فعلی نوشته شده است؛ چون OpenAPI رسمی در مخزن وجود ندارد، هر تغییر مستقیم در فایل‌های PHP باید هم‌زمان در این سند نیز بازتاب پیدا کند.
- کلاینت‌ها باید برای 401 و 403 رفتار جداگانه داشته باشند؛ اولی معمولاً نیازمند login مجدد است، دومی نشان‌دهنده نبود دسترسی یا غیرفعال بودن tenant/site/feature است.
- در API ویجت، نبود پاسخ AI لزوماً خطا نیست؛ ممکن است به دلیل حضور اپراتور آنلاین، غیرفعال بودن پاسخ خودکار، کمبود اطمینان پاسخ یا بسته بودن گفتگو رخ دهد.
- چون موتور AI فعال از منابع دانش داخلی استفاده می‌کند، کیفیت پاسخ‌های AI مستقیماً به کامل بودن knowledge، منابع crawl و وضعیت سوالات بی‌پاسخ وابسته است.

۸ چک‌لیست مصرف API

۱. برای پیل، ابتدا auth/login.php را فراخوانی و توکن را در هدر Authorization ارسال کنید.
۲. قبل از هر عملیات سایت‌محور، site_id معتبر و متعلق به tenant کاربر را انتخاب کنید.
۳. برای ویجت، site_key را در همه درخواست‌های عمومی ارسال کنید و دامنه نصب را با تنظیمات سایت هم‌خوان نگه دارید.
۴. برای endpointهای دارای کنترل نرخ، وضعیت 429 و هدر Retry-After را در کلاینت رعایت کنید.
۵. برای آپلود فایل از multipart/form-data استفاده کنید و خطاهای اندازه/نوع فایل را برای کاربر نمایش دهید.
۶. در محیط production، به جزئیات debug وابسته نشوید و لاگ داخلی سرور را منبع عیب‌یابی قرار دهید.